

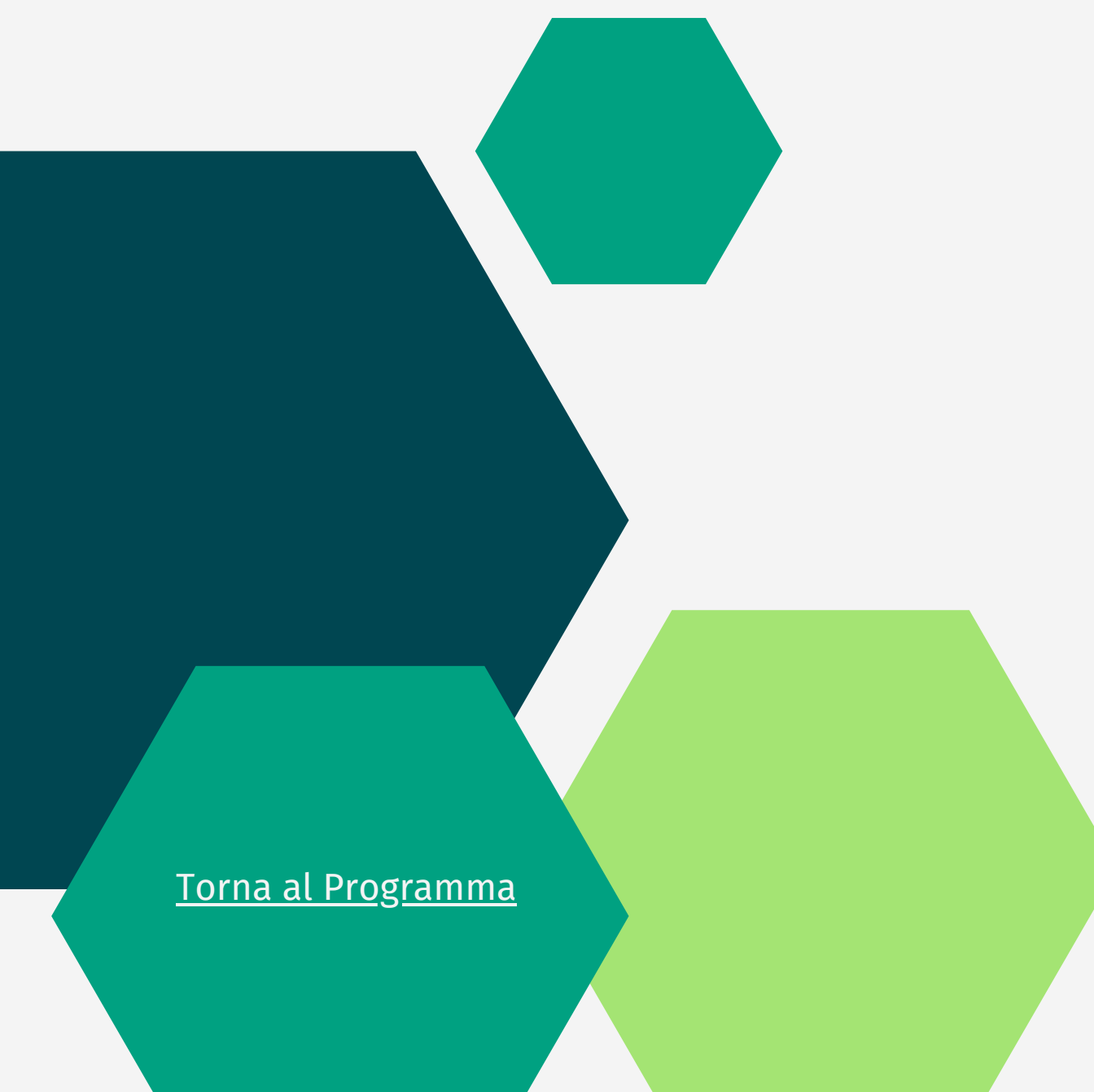


Matteo Pillinini

Static code analysis lab



Tools & Repos



[Torna al Programma](#)

Sonar Qube cloud

Static application security testing (SAST)

Dependency check

Software composition analysis (SCA)

Damn Vulnerable C Program(DVCP)

[link](#)

Information retrieval system (by me)

[link](#)



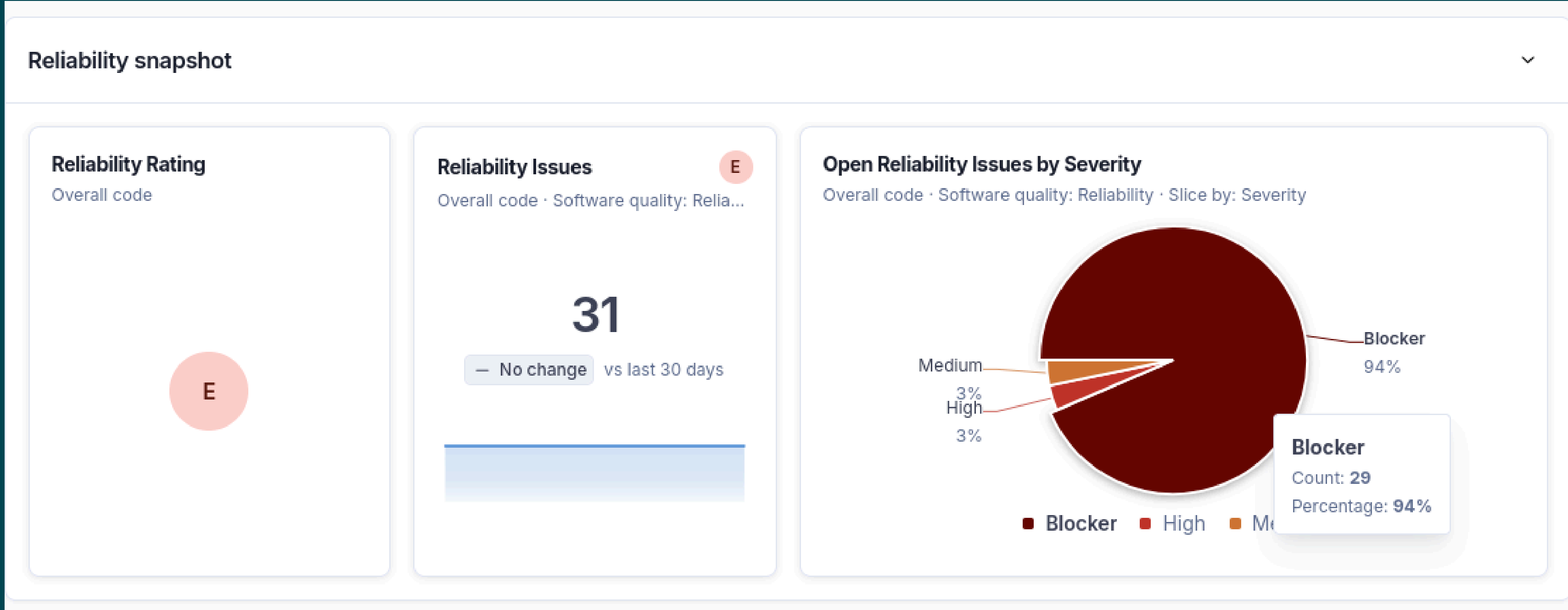
Well know vulnerable project

Damn Vulnerable C Program

- The program is coded for being exploited
- Use After Free
- Memory leaks
- Stack exhaustion
- Heap exhaustion



Sonar Qube overview



Issue found CWE-416

unintuitive and
hard diagnose
bugs

```
//double free  
7 if ( 6 size1 % 2 == 0){  
    free(buff1);  
}  
else{  
    //use after free  
9 if( 8 size1 % 3 == 0){  
    buff1[0] 10 = 'a';
```

Use of memory after it is freed



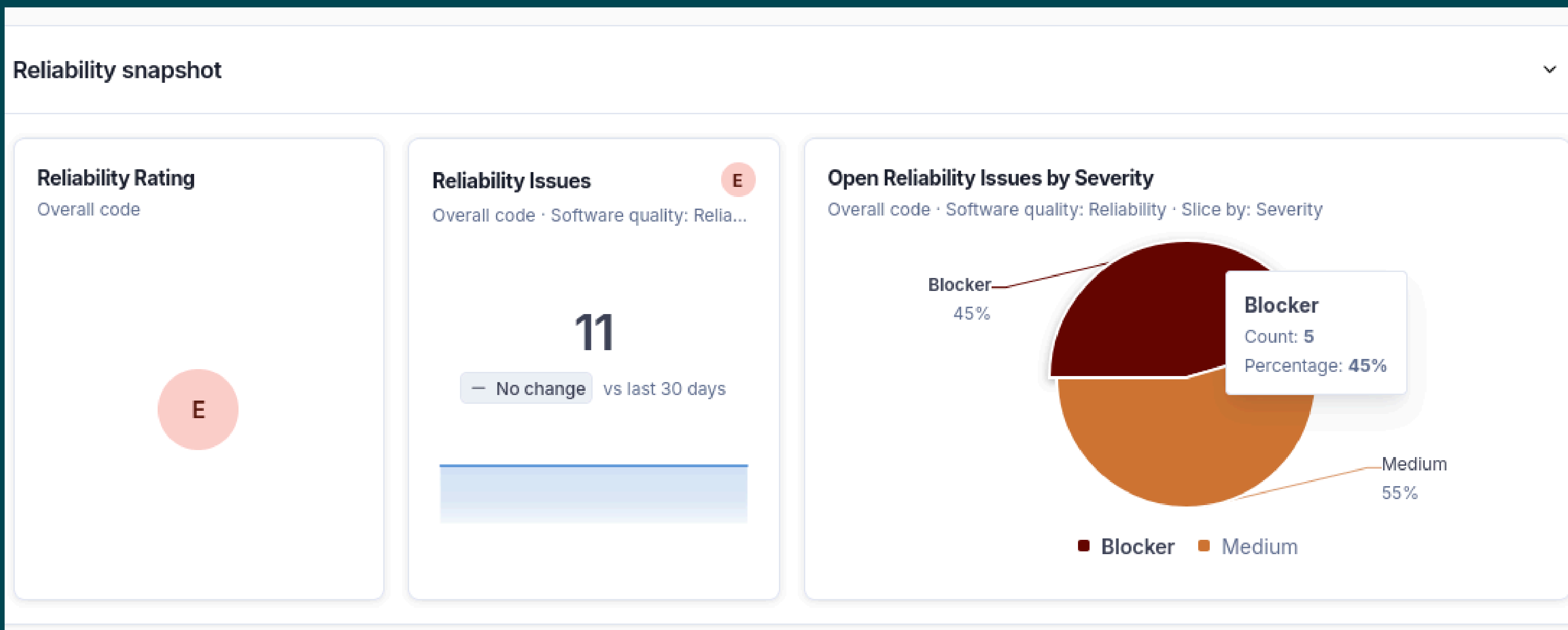
Not know vulnerable project

Information retrieval exam

- The program is a boolean information retrieval system



Sonar Qube overview



Issue found CWE-119,121,...

Out-of-bounds
memory
accesses

```
int length = 0;
for (int i = 0; i < char_length; i++)
    if (!(char_ids[i] & 0x80))
        length++;

int *ids = 2 * malloc(sizeof(int) * length);
int pos_ids = 0;
int step = 0;
int last = 0;
for (int i = 0; pos_ids < char_length; i++) {
    1 ids[i] = decode_int(char_ids + pos_ids, &step)+last;
```

Access of the heap area at index 1, while it holds only a single 'int' element

Issue found CWE-401

Possible DoS
attack

```
void reduced_get_dict_and_ids(dictionary *d, int **is, int *len) {  
    dictionary dict = 1 malloc(sizeof(struct _dictionary));  
    if (dict == NULL)  
        return;  
  
    int N;  
    fseek(rptr, 0, SEEK_SET);  
    fread(&N, sizeof(int), 1, rptr);  
  
    dict->word = malloc(sizeof(char *) * ((N + BLOCK_SIZE - 1) / BLOCK_SIZE));  
    dict->pos = malloc(sizeof(size_t) * N);  
    int *isd = malloc(sizeof(int) * N);  
    if (isd == NULL)  
        return;  
}
```

Potential leak of memory pointed to by 'dict'

Conclusion

BOTH:

- No dependency on other packages
- The dependency check found no issues
- Language used C
- I Sonar Qube was able to find issue

MY PROJECT

- Even without user input a lot of severe vulnerability were found